

WE LIKE TO
SHOP



Lightbulb Moments
★★★★★ \$85.48

[View details](#)



High-End Gift Wrapping
★★★★★ \$87.35

[View details](#)



Cheshire Cat Grin
★★★☆☆ \$79.47

[View details](#)



Giant Grasshopper
★★★★★ \$80.65

[View details](#)



Actividad 07

File Path Traversal: Simple Case

Lizbeth Guerrero Hurtado

Marco Teórico

¿Qué es File Path Traversal?

File Path Traversal (también conocido como Directory Traversal) es una vulnerabilidad de seguridad web crítica que permite a un atacante leer archivos arbitrarios en el servidor que ejecuta la aplicación. Esto puede incluir código fuente de la aplicación, datos de configuración, archivos del sistema operativo y credenciales sensibles.

Mecanismo de Explotación (Secuencia Dot-Dot-Slash)

La vulnerabilidad surge cuando una aplicación web pasa la entrada del usuario directamente a una API de archivo del sistema operativo sin la debida sanitización o validación. Al utilizar secuencias de escape de directorio como `../` (en sistemas Unix/Linux) o `..\` (en Windows), el atacante puede retroceder en la estructura jerárquica de directorios del sistema de archivos, escapando de la raíz web (root directory) asignada a la aplicación.

Punto Clave de Seguridad

En sistemas Linux, el archivo `/etc/passwd` contiene información básica sobre todas las cuentas de usuario registradas en el sistema. Aunque históricamente almacenaba hashes de contraseñas (ahora movidos a `/etc/shadow`), sigue siendo el objetivo estándar para pruebas de concepto (PoC) debido a que es ejecutable y legible globalmente.

Impacto en la Tríada CIA

Confidencialidad: Es el impacto primario. Permite la exfiltración de credenciales, claves SSH privadas, archivos de configuración `.env` (con tokens de API y contraseñas de BD) y código fuente.

Integridad: Si se combina con otras vulnerabilidades (como Write Traversal), un atacante podría sobrescribir archivos del sistema o configuraciones.

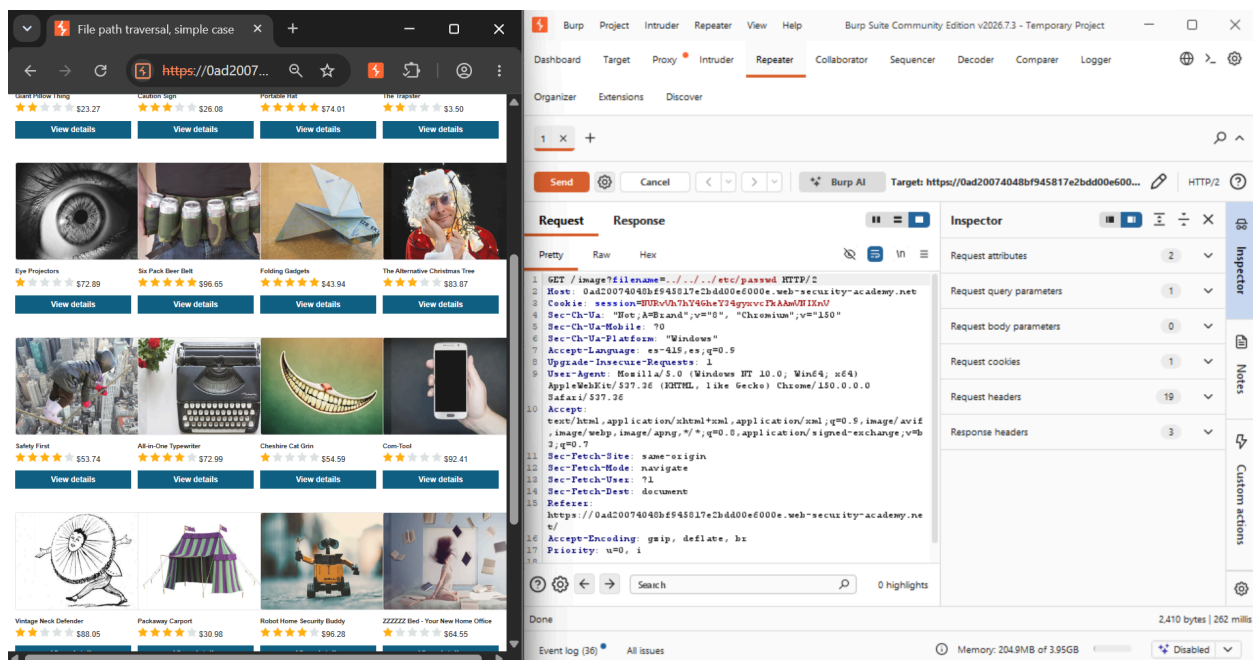
Disponibilidad: El acceso a archivos de registro o dispositivos del sistema (ej. `/dev/zero` en Linux) podría ser utilizado para causar una denegación de servicio (DoS) mediante el consumo de recursos.

Procedimiento de Explotación

El proceso se llevó a cabo utilizando herramientas de interceptación para manipular la solicitud HTTP en tránsito.

Metodología en Burp Suite

- **Intercepción:** Se activó el Proxy y se navegó por la aplicación hasta encontrar una funcionalidad de visualización de imágenes.
- **HTTP History:** Se identificó la solicitud GET que cargaba una imagen: GET /image?filename=6.jpg.
- **Repeater:** Se envió la solicitud al módulo Repeater (Ctrl+R) para realizar pruebas iterativas.
- **Inyección de Payload:** Se modificó el parámetro filename reemplazando 6.jpg por ../../../../etc/passwd.
- **Confirmación:** Al enviar la solicitud, el servidor respondió con un código 200 OK y el contenido del archivo de usuarios del sistema en el cuerpo de la respuesta.



Estrategias de Mitigación Recomendadas

Para prevenir de manera definitiva las vulnerabilidades de File Path Traversal, se deben implementar los siguientes controles de desarrollo seguro:

Evitar el paso directo de nombres de archivo: La mejor defensa es no pasar datos ingresados por el usuario a las APIs de archivos. En su lugar, utilice un identificador numérico o clave única (ej. /image?id=123) y mapee este valor en la base de datos.

Conclusiones y Aprendizaje

La actividad nos demuestra que la confianza ciega en la entrada del usuario es uno de los riesgos más críticos en el desarrollo web. A través de este laboratorio, se comprendió que:

- Las funciones de manejo de archivos son vectores críticos que requieren saneamiento estricto.
- El conocimiento de la estructura de archivos del sistema operativo es fundamental para un auditor de seguridad.
- La mitigación más efectiva no es intentar "filtrar" caracteres malos (listas negras), sino validar que el resultado final de la operación se mantenga dentro de los límites lógicos permitidos (canonicalización y listas blancas).